Data Privacy & Security Note

Architectural Security Controls, Statutory DPDP Alignment & Boundary Disclosures

SINGLE-PAGE BRIEF | DPDP ACT 2023 ALIGNED | MODULAR MONOLITH

01. Privacy by Design & Purpose Limitation

Accel Business implements strict data minimisation under the Digital Personal Data Protection (DPDP) framework. The platform collects only operational sizing parameters (employees, sites, city, telecom services) and statutory identifiers (GSTIN, Udyam) necessary for service feasibility and Customer Due Diligence (CDD) under Department of Telecommunications (DoT) directives.

Before document submission, an affirmative statutory consent gate explicitly details the specified purpose, data categories, 30-day unactivated purge policy, subscriber principal rights, and designated Grievance Officer (`grievance-officer@accelbusiness.in`).

02. Sensitive Data Handling & Local OCR Processing

Statutory business identity documents (GST Certificate, Udyam, Signatory ID, Address Proof) uploaded through the browser are decoded directly in-memory via OpenCV (`np.frombuffer` → `cv2.imdecode`) and are **never persisted to disk**.

Character recognition is executed locally via Tesseract OCR (`tesseract.exe`) with zero transmission to external cloud vision services. Sensitive identifiers are masked across the user interface and audit logs (`mask_identifier()`), displaying only the last 4 digits of Aadhaar/GSTIN and tokenized Udyam formats. In-memory arrays are purged immediately on session termination.

03. Application Security & Guardrails

- **Input Boundaries**: `engine/guardrails.py` clamps inputs before widget initialization (1 to 10,000 employees, 1 to 500 sites, budget ≤ ₹10,00,000) and strictly rejects hallucinated products or non-catalogue prices.
- **Upload Hardening**: File uploaders enforce MIME whitelisting (`.png`, `.jpg`, `.jpeg`), 10MB limits, empty-file blocks, and OpenCV image decoding verification.
- **Session & Secret Hygiene**: State is isolated per session in `st.session_state`. Sensitive keys (`GEMINI_API_KEY`) reside in `.env`, quarantined by `.gitignore`. Streamlit usage telemetry is disabled (`gatherUsageStats = false`).

04. External Integration Boundaries

- **Google Gemini API** `IMPLEMENTED`: Optional requirement extraction (default OFF). Transmits only natural language text over IPv4 (`0.0.0.0`) with a 10s strict timeout; zero document or biometric data is shared.
- **Tesseract OCR** `IMPLEMENTED`: Localhost binary execution; zero outbound network activity.
- **Statutory Registries** `SIMULATED`: In-memory verification against mock CSV registries with algorithmic Luhn-mod-36 checksum checks.
- **e-NACH Mandate & Telecom BSS** `SIMULATED`: UI-simulated mandate flow and 5-stage provisioning state machine; no live banking credentials are held.

05. Indian Data Protection Considerations

The architecture aligns with the core principles of the **Digital Personal Data Protection Act, 2023** and draft **DPDP Rules, 2025**: purpose limitation, transparent notice, affirmative consent, and reasonable security safeguards (local processing, PII masking). *This document reflects technical architectural alignment and does not constitute formal legal certification.*

06. Limitations & Future Improvements

- **Encryption at Rest** `PLANNED`: `data/orders.json` stores orders in plaintext JSON; AES-256 field-level encryption is required for production.
- **Role-Based Access Control (RBAC)** `PLANNED`: No role barrier between subscriber onboarding and the compliance audit desk.
- **Automated Lifecycle Purge** `PLANNED`: The 30-day unactivated document purge policy requires an automated background daemon.
- **Production Gateways** `PLANNED`: Live GSTN/MCA API integration and NPCI e-Mandate gateways.

VERIFIED DATA BOUNDARY FLOW

```
User Upload → [In-Memory CV2] → [Local Tesseract OCR] →
[Checksum / Mock CSV]
Natural Language → [Rules Engine / Optional Gemini IPv4] →
[Order JSON Store]
```